PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Vulnérabilités critiques Linux et sécurité Debian

06-730 PSE 25-27 5-15 Linux - La sécurité sous Debian 13 (partie 2), vulnérabilités critiques 2026 — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. Le premier semestre 2026 recense plus de 1900 CVE détectées par IA.
2. L'interface AF_ALG combinée à splice() fait pointer une opération sur le page cache et permet de modifier un binaire SUID root sans droit d'écriture.
3. La défense en profondeur repose sur la superposition de mécanismes comme nftables, AppArmor ou auditd.

Synthèse des mécanismes de vulnérabilités

Notion	À retenir
Vague de vulnérabilités 2026	Plus de **1900 CVE** recensées au **1er semestre 2026** ; détection de bogues invisibles depuis **15 à 18 ans** via **IA**.
Cache de pages	Copie en **mémoire vive** partagée entre processus ; constitue une **seconde voie d'accès** contournant les vérifications de permission de `open()` ou `write()`.
Détournement interfaces	Utilisation de `AF_ALG` et `splice()` pour pointer sur le **page cache** ; permet de modifier un binaire **SUID root** sans droits d'écriture.

Synthèse des familles de failles critiques

Notion	À retenir
Copy Fail	CVE-2026-31431 (**algif_aead**) : détournement du cache via `splice()` pour patcher un binaire **SUID root**.
Dirty Frag	CVE-2026-43284, CVE-2026-43500 : réutilisation de pages de cache via **IPsec (ESP)** ou **RxRPC**.
KVM	Évasion VM : **ITScape** (arm64, CVE-2026-46316) et **Januscape** (x86, CVE-2026-53359, CVE-2026-46113) via **shadow paging**.
Concurrence	GhostLock (CVE-2026-43499, **futex**) : accès **root** ou évasion conteneur. Bad Epoll (CVE-2026-46242, **use-after-free**) : cible serveurs réseau.

Vulnérabilités et principes de sécurité

Notion	À retenir
Protocole Telnet	Menace critique (**CVE-2026-32746**, score **9,8**) et **CVE-2026-24061** (accès **root** en une commande, exploitation active **CISA**) via `telnetd` de **GNU InetUtils**.
Réduction surface d'attaque	Principe fondamental consistant à **limiter les composants exposés** pour réduire les risques et prévenir l'exploitation de services comme `nginx` ou **GNU InetUtils**.

Principes fondamentaux de la sécurité système

Notion	À retenir
Défense en profondeur	Superposition de mécanismes indépendants (**réseau**, **système**, **application**) : `nftables`, **AppArmor**, `auditd` ; le contrôle d'accès obligatoire **limite les dégâts** même si une faille est exploitée.
Moindre privilège	Chaque compte ou service n'a que les **droits strictement nécessaires** : **capabilities** plutôt que **SUID**, **ACL**, `chroot`, chartes d'habilitation ; désactiver les services obsolètes (**Telnet**).
Amélioration continue	Processus dynamique : **veille CVE**, mises à jour proactives (`unattended-upgrades`), **audits**, **tests de restauration**, révisions de la **PSSI**.

Synthèse des mesures de sécurité Debian

Notion	À retenir
Protection données/accès	Disponibilité/intégrité : sauvegardes `borgbackup`, `restic`, `rsync` ; mises à jour `apt`, `unattended-upgrades`, `debsecan`. **LVM** et options `fstab` (disponibilité, confidentialité). Confidentialité/preuve : **PAM** (`pam_faillock`, `pam_pwquality`), `chage`. Réseau : `nftables`, `fail2ban`, **SSH**.
Gestion traces/comptabilité	Preuve/traçabilité via `journald`, `auditd`, `rsyslog`. Comptabilité via paquet `acct` (`lastcomm`, `sa`). Historique des connexions via `last` et `lastb`. `auditd` définit des règles sur **fichiers sensibles**.
Contrôle droits/isolation	Confidentialité/intégrité via **ACL**, `chattr`, **capabilities**, `AppArmor`. Isolation via `chroot` (insuffisante face à **root**). Authentification AAA via **RADIUS**. Réduction surface d'attaque : privilégier **capabilities** au **SUID**.

Synthèse de la méthodologie de durcissement

Notion	À retenir
Check-list de durcissement	Sauvegardes **3-2-1** (chiffrées/isolées), partitionnement `/tmp`, `/var/log`, `/boot` (**nosuid**, **nodev**, **noexec**), `unattended-upgrades`, `debsecan`, `nftables` (**drop**), `fail2ban`, SSH (**PermitRootLogin no**), `auditd`, `acct`.
Gouvernance (PSSI)	Formalisée, diffusée, révisée **au moins une fois par an** avec **charte informatique signée**. Utilise **EBIOS RM**, la **défense en profondeur** et le **moindre privilège** (**capabilities**, **ACL**, **chroot**).

Pièges et confusions

⚠ Confondre la faille Copy Fail avec le mécanisme SUID lui-même.
⚠ Croire que la désactivation du module algif_aead protège contre la famille Dirty Frag.
⚠ Confondre les failles déterministes (Copy Fail, Dirty Frag) avec les failles par condition de course (GhostLock, Bad Epoll).
⚠ Considérer l'utilisation du chroot comme une isolation suffisante face à un utilisateur root.
⚠ Penser que la protection AppArmor ou SELinux contre Copy Fail est automatique sans profil spécifique pour les sockets AF_ALG.

Sigles et définitions

CVE identifiant standard pour une vulnérabilité publiée
page cache zone mémoire gérée par le noyau qui conserve une copie du contenu d'un fichier
SUID mécanisme permettant à un binaire de s'exécuter avec les droits de son propriétaire
KVM hyperviseur intégré au noyau Linux pour gérer des machines virtuelles
CVSS système de notation utilisé pour évaluer la criticité d'une vulnérabilité
LPE vulnérabilité d'escalade de privilèges locale
ANSSI autorité française de référence pour la sécurité des systèmes d'information
DSA avis de sécurité officiel publié par le projet Debian

Auto-test

1. Quelle vulnérabilité utilise le détournement du cache via splice() pour patcher un binaire SUID root ?
2. Quels sont les deux types d'évasion de VM identifiés via shadow paging ?
3. Quel protocole présente une menace critique avec un score de 9,8 ?
4. Quelle mesure est considérée comme une mesure de confidentialité et d'intégrité complémentaire mais insuffisante face à root ?
5. Quel outil permet de définir des règles sur les fichiers sensibles pour la traçabilité ?

Réponses : **1.** Copy Fail (CVE-2026-31431) · **2.** ITScape et Januscape · **3.** Telnet · **4.** Le chroot · **5.** auditd

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.